

- **Expediente N.º: EXP202306832**

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: Con fecha 11 de abril de 2023 se interpusieron seis reclamaciones ante la Agencia Española de Protección de Datos por una posible infracción imputable a **MAD COOL FESTIVAL, S.L.** con NIF **B87381042** (en adelante, *MAD COOL*).

Los hechos que se ponen en conocimiento de esta autoridad son los siguientes:

Los reclamantes manifiestan haber sido afectadas por la brecha de datos personales que tuvo lugar en el sitio web <https://www.madcoolarea.es/area/> el pasado 11 de abril de 23.

Ese día MAD COOL abrió dicha página web para confirmar los datos de envío de unas pulseras para el festival de música que organizaba. Una vez introducidos los datos de acceso (cuenta de correo y el código de entrada) por los usuarios, se podían visualizar los datos personales de otras personas que también se encontraban dadas de alta en la plataforma.

Junto a los escritos, se aporta:

- Capturas de pantalla de la plataforma de la parte reclamada en el momento del incidente, donde se muestran datos de terceros (nombre, apellidos, correo electrónico, teléfono, dirección postal, código postal, población y país).
- Correo electrónico enviado por la parte reclamada el 11 de abril de 2023 en el que instaba a acceder a su página web para confirmar la dirección postal para el envío de pulseras.

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), se dio traslado de dicha reclamación a MAD COOL, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

MAD COOL ha dado respuesta al requerimiento mediante escrito de fecha 23 y 30 de junio de 2023.

TERCERO: Con fecha 10 de julio de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación.

CUARTO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VIII, de la LOPDGDD.

Como consecuencia de las actuaciones realizadas, se ha tenido conocimiento de los siguientes extremos:

1.- Notificación de la brecha.

MAD COOL confirma, en su respuesta al traslado, que no realizó notificación de brecha ante esta Agencia. Tal como manifiesta: *“La violación de seguridad no ha sido comunicada ante la Agencia Española de Protección de Datos ya que no ha supuesto un riesgo o riesgo alto para los derechos y las libertades fundamentales de las personas físicas. Se llega a dicha conclusión tras haber analizado cualitativa y cuantitativamente el incidente ocurrido y teniendo en cuenta distintos parámetros como volumen de datos afectados, categoría o tipología de datos afectados y escala de exposición de los mismos”*.

2.- Análisis de la brecha.

2.1. Cronología de los hechos.

La cronología de los hechos del incidente según las Subdirección General de Inspección de Datos actuaciones es la siguiente:

El día 11 de abril de 2023 tuvo lugar por parte de MAD COOL, el lanzamiento de un formulario de confirmación de los datos personales de los usuarios que adquirieron las entradas al festival que se celebraba en el mes de julio de dicho año. En el momento de dicho lanzamiento tuvo lugar el incidente de seguridad que ocasionó la brecha.

El origen del problema se debió a que durante la mañana del lanzamiento del formulario web, se realizó una migración de la plataforma a un servidor nuevo y en el transcurso de esa migración no fue desactivado una micro-caché existente en ese servidor. MAD COOL manifiesta sobre este error de configuración del servidor: *“se trata, por tanto, de un error humano, puntual y totalmente involuntario”*.

Esta micro-caché de 2 segundos ocasionaba que desde que un usuario accedía al formulario, durante un máximo de 2 segundos, los siguientes usuarios que accedían vieran sus datos. Una vez transcurrían esos 2 segundos, los datos del usuario dejaban de mostrarse. Según se aporta en las manifestaciones: *“Cuando un usuario hacía login en el formulario, los siguientes que accedían durante los dos primeros segundos siguientes podían ver los datos de otra persona en lugar de los suyos. Los usuarios solo veían sus propios datos cuando nadie había hecho login antes de esos dos segundos.”*

En un inicio MAD COOL manifestó que detectó el fallo a las 15:15 del día 11 de abril y se procedió a cerrar al formulario en cuestión, para minimizar el impacto de la brecha. Tal como señalaba inicialmente MAD COOL, a las 15:45 se considera que se encontraba solucionado el problema. Posteriormente, se matizó que la ventana temporal del incidente sería desde las 14:45 hasta las 15:15. Esta última versión resulta coherente con la documentación acreditativa aportada relativa al número de usuarios afectados, así como el informe del encargado del tratamiento.

El 12 de abril de 2023, MAD COOL manifiesta que comenzó a recibir correos electrónicos de usuarios afectados por el incidente, informando del mismo y solicitando explicaciones de lo acontecido. Con posterioridad, el 13 de abril de 2023, MAD COOL hizo público un comunicado en su página web, como se detallará posteriormente.

2.2. Acciones tomadas con objeto de minimizar los efectos adversos y medidas adoptadas para su resolución final.

Como se ha indicado, una vez se tuvo constancia del incidente se procedió a cerrar el acceso al formulario para que no hubiera un número mayor de usuarios involucrados en la brecha. MAD COOL manifiesta lo siguiente al respecto: *“En el momento en que tuvo lugar el incidente de seguridad al producirse la migración de un servidor a otro, se llevó a cabo el cierre inmediato del acceso al formulario, se realizó una completa revisión de toda la seguridad del mismo y se desactivó el micro-cacheo del servidor. Una vez se comprobó que todo estaba en orden se restauró el formulario web. Todo ello en un período de tiempo de treinta minutos.”*

Dichas acciones fueron realizadas por el encargado del tratamiento, que era quien gestionó a nivel técnico el incidente. Según manifiesta MAD COOL: *“en cuanto nuestro proveedor del servicio, *****CONSULTORIA.1.**, tuvo conocimiento del incidente, se cerró la web para tomar las medidas adecuadas a lo sucedido y que también se aclaran a lo largo del presente. En concreto, se detecta el fallo a las 15.15hs (...), inmediatamente se cierra el acceso a los usuarios al formulario en cuestión y a las 15.45hs ya estaba solucionado el problema.”*

El mismo (...) de 2023, la violación de seguridad queda analizada y registrada por parte de *****CONSULTORIA.1.** al ser esta entidad objeto de la misma y dicha documentación es facilitada a MAD COOL.

Adicionalmente, se aporta análisis de la violación de seguridad y registro del incidente, elaborado por el encargado del tratamiento. La descripción del incidente que consta es: *“En el lanzamiento de un formulario de confirmación de datos del festival Mad Cool 2023, algunos usuarios han podido ver datos de otros usuarios, que no les correspondía. Ha afectado a (...) usuarios.”*

2.3. Respecto de las causas que hicieron posible la brecha

Como se ha señalado, de acuerdo con las manifestaciones de MAD COOL, el origen de la brecha estuvo ocasionado por una configuración errónea del servidor que aloja la plataforma, causada por un error humano en la revisión durante el despliegue de un formulario web.

Este despliegue se ejecutó a su vez debido a una migración del entorno tecnológico realizada en el mismo día del suceso. En el informe elaborado por el encargado se refleja este hecho y la motivación de esta acción: *“Se decidió realizar una migración la misma mañana porque se esperaba un gran volumen de usuarios accediendo al formulario, y se trasladó el sistema a un servidor más potente. Este servidor tenía un micro-caché activado y, hasta que no se desactivó, no se solucionó el problema.”*

La habilitación de esa micro-caché tenía como consecuencia que, durante un periodo de tiempo, 2 segundos según manifiesta MAD COOL, cuando un usuario accedía al formulario sus datos podían ser visualizados por otros usuarios que estuvieran también en ese momento en la plataforma. Tal como manifiestan los reclamantes, este comportamiento sería coherente con la descripción de los hechos aportada, en la que era posible visualizar los datos diferentes usuarios al recargar la página web.

Se aporta informe técnico del encargado del tratamiento con los detalles técnicos del incidente y el funcionamiento de la micro-caché. Cabe señalar que el entorno tecnológico se encontraba desplegado en la infraestructura de un tercero en calidad de subencargado del tratamiento, la entidad *****COMPAÑIA.1**. El encargado del tratamiento manifiesta al respecto: *“El software se aloja en los servidores de ***COMPAÑIA.1. Esta compañía ofrece por defecto un servicio de micro-cache para acelerar la carga de páginas webs.”*

Las medidas de seguridad que se encontraban disponibles, enfocadas a ataques por parte de terceros maliciosos (...), no resultan de aplicación ante este tipo de casuística interna.

2.4. Impacto de la brecha.

Según indica MAD COOL, el total de potenciales afectados fue de (...) usuarios, los cuales tuvieron acceso al formulario web hasta la detección del incidente y cierre de la plataforma. Tal como se indica en el informe elaborado por el encargado: *“Ello no quiere decir que los datos fueran visibles por todos los usuarios que accedieron a la plataforma ni que todos los usuarios pudieran acceder a todos los datos”*.

En base a eso, la magnitud exacta del impacto no se puede determinar, ya que no es posible conocer con certeza qué usuarios vieron qué datos. Según manifiesta MAD COOL: *“((...)) personas existen tanto posibles vulnerados como personas cuyos datos sí fueron vulnerados con total seguridad. Por tanto, de la cifra de (...) personas concluimos que no tenemos la seguridad cien por cien de que todos hayan sido finalmente sujetos afectados englobando en el desglose efectuado en el archivo adjunto, tanto los potenciales afectados como los afectados con total seguridad”*

Se aporta un listado de usuarios afectados, con los datos que se vieron involucrados en la brecha. MAD COOL facilita una relación de usuarios afectados con certeza y otra de posibles afectados. Del total de (...) usuarios, (...) constan como *“posibles vulnerados”*, mientras que (...) habrían visto sus datos vulnerados con certeza. Figura asimismo la fecha y hora de acceso, agrupándose en un intervalo de 32 minutos entre las 14:43 y las 15:15, a excepción de un usuario que accedió a las 14:16.

Ante la cuestión del usuario que accedió fuera de la ventana temporal de la brecha, MAD COOL manifiesta lo siguiente: *“A las 14:43hs se mandó un mailing masivo a los asistentes para que accedieran a la plataforma, y entraron (...) personas hasta las 15:15hs que cerramos la plataforma.*

Ese usuario que accedió antes lo hizo de forma esporádica, porque la plataforma estaba publicada pero no anunciada, de modo que pudo entrar a las 14:16hs. Ese usuario lo hemos incluido en el listado porque accedió durante el día, pero no se vio afectado porque el problema solamente afectaba a aquellos que entraban en menos de 2 segundos después del anterior, lo cual sucedió al mandar el mailing masivo de las 14:43hs”.

El total de usuarios registrados en la plataforma era de 29.140 personas.

Los datos afectados por la brecha han sido los siguientes:

- Nombre y apellidos.
- Dirección postal.
- Número de teléfono.
- Correo electrónico.

Por último, ante el posible compromiso de la integridad, MAD COOL manifiesta: *“Los datos que los usuarios modificasen durante el tiempo que duró el incidente se desecharon y, cuando se solucionó el problema, se reimportaron los datos originales, de modo que ningún cambio de datos de ese periodo ha sido tenido en cuenta”.*

2.5. Comunicaciones mantenidas para la resolución de la brecha.

Se aporta copia del comunicado remitido por el encargado al responsable del tratamiento. Dicho documento se encuentra firmado a fecha 13 de abril de 2023 y en él se relatan los hechos, sin entrar en un gran nivel de detalle sobre el origen del incidente: *“La violación de seguridad sufrida ha provocado un acceso no autorizado de datos de carácter personal, concretamente, a datos identificativos de los afectados por parte de otros clientes”.* En cualquier caso, sí consta en él número de afectados, tipología de datos involucrados y ventana temporal del incidente.

Junto con esa comunicación se aporta copia del análisis del incidente, ya mencionado previamente.

Adicionalmente, se aportan las comunicaciones entre el encargado del tratamiento y el subencargado (*****COMPAÑIA.1**). No constan comunicaciones en la fecha de los hechos, puesto que según manifiesta se borran transcurrido un año. Las comunicaciones que se facilitan son entre los días 3 y 6 de octubre de 2023, a partir del requerimiento efectuado por esta Agencia según manifiestan. En ellas el representante del encargado solicita acreditación del funcionamiento de la microcaché y según las conversaciones mantenidas el subencargado confirma el funcionamiento previamente detallado por un intervalo de 2 segundos.

2.6.- Posibles consecuencias para los afectados y valoración del incidente por parte del responsable.

MAD COOL manifiesta lo siguiente al respecto: *“Dada la tipología de datos afectados por el incidente de seguridad se entiende que NO se ha perjudicado a los derechos y las libertades de los usuarios, en ningún momento. No ha tenido lugar daño alguno a datos englobados dentro de la categoría especial de datos personales o datos especialmente sensibles. Importante resaltar, en este punto, que no han quedado expuestos datos personales que suelen preocupar mucho a los clientes como son los relacionados con datos de pago, por ejemplo, números de tarjetas bancarias.”*

Por otra parte, el encargado de tratamiento, en el análisis del incidente, concluye: *“La observación de este conjunto, nos lleva a estimar que nos enfrentamos ante una brecha de seguridad, en concreto en lo tocante a la confidencialidad de los datos de carácter personal. En consecuencia y tras el análisis realizado, podemos observar cómo sus valores cuantitativos y cualitativos no suponen un riesgo para los derechos y libertades de las personas físicas.*

En definitiva, no es considerado como alto riesgo, según el criterio dado por el Reglamento (UE) 2016/679, por ello, no se detecta la necesidad de notificar el incidente a la autoridad de control competente, ni a los interesados afectados.”

En consecuencia, tal como se ha comentado en el primer punto de este informe, MAD COOL no realizó notificación ante esta Agencia.

3. Comunicación a los afectados.

MAD COOL hizo público el día 13 de abril de 2023 un comunicado informativo del incidente. Dicho comunicado *“estuvo visible en la página web durante varias semanas”*, según manifiesta.

Se aporta copia del comunicado publicado. En él se informa del incidente, si bien no se profundiza en su origen ni tipología de los datos afectados, ni tampoco se concretan las medidas adoptadas. Se reproduce a continuación un fragmento del mismo: *“En relación con las últimas noticias relacionas con el incidente de visualización de entradas en la página web del MAD COOL AREA, en la que sus datos personales se han podido ver afectados queremos indicarle que, desde el momento en que conocimos este incidente, hemos sido los principales interesados en esclarecer los hechos.*

En tal sentido, hemos realizado un análisis cuantitativo y cualitativo de los riesgos, teniendo en cuenta el volumen y el posible impacto de este incidente en los derechos y libertades de los interesados. Como resultado del mismo, hemos podido comprobar que el incidente de seguridad no ha supuesto un alto riesgo para los derechos y libertades de las personas físicas.”

Se aporta un correo electrónico para la resolución de dudas al respecto: *“Desde nuestra entidad queremos ser transparentes por los inconvenientes causados y nos ponemos a disposición de cualquier interesado para ayudarle en cualquier duda que le pueda surgir, así como para informarle en relación con la protección de sus datos personales. Por ello, rogamos que cualquier duda que pueda tener o comentario que desee transmitirnos, lo haga llegar a la dirección de correo electrónico pulseras@madcool.es, desde la que le daremos una respuesta personalizada”*

4.- Respecto de las medidas de seguridad implantadas

4.1. Medidas de seguridad implantadas con anterioridad a la brecha en los tratamientos de datos donde se ha producido.

MAD COOL ha aportado copia de la auditoría realizada, a fecha 1 de marzo de 2022, al encargado del tratamiento. El alcance comprende los tratamientos automatizados y manuales de datos personales responsabilidad de la persona o entidad auditada. Las actividades de tratamiento auditadas son:

- Atención a los derechos de las personas
- Clientes
- Notificación y comunicación de las violaciones de la seguridad de los datos personales a la autoridad de control y a los interesados
- Prevención de Riesgos Laborales
- Proveedores
- Publicidad y prospección comercial
- Recursos Humanos
- Registro diario de jornada
- Usuarios página web

La valoración es favorable, señalando el informe: *“En la persona o entidad auditada se cumplen, con carácter general, las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad de los datos adecuado al riesgo, si bien todavía existen algunas salvedades que aconsejan la adopción de las medidas correctoras o complementarias necesarias.”*.

Se verifica la existencia de la siguiente medida: *“Servidor web propio. Se examina la existencia de un servidor web propiedad de la entidad responsable del tratamiento.”*. La aplicación efectiva de dicha medida, a priori, no hubiera requerido de la prestación de servicios por parte del subencargado del tratamiento.

Adicionalmente, se aporta copia del documento de control periódico a fecha 3 de mayo de 2023, realizado igualmente por *****CONSULTORA.2.**, cuya valoración es favorable. Se aporta también documento de *“Gestiones de violaciones de seguridad de los datos”*

Se ha requerido al encargado del tratamiento información sobre el procedimiento existente en el momento de los hechos para la realización de despliegues/migraciones, así como la batería de pruebas disponible.

El encargado ha facilitado información sobre los procedimientos de test de formularios y despliegue en servidores, así como la batería de pruebas realizada. Entre dichos procedimientos se encuentran recogidas las siguientes comprobaciones:

- (...)
- (...)
- (...)
- (...)

Adicionalmente se aporta acreditación de las pruebas realizadas para el despliegue en cuestión que ocasionó la brecha, mediante la herramienta *****HERRAMIENTA.1**. Según

manifiesta el encargado del tratamiento: “En cuanto a las pruebas realizadas para el despliegue que ocasionó el incidente, hemos documentado todas las pruebas. Entre las pruebas realizadas se incluyen:

- (...)
- (...)
- (...)
- (...)

Una vez validado el código, se procedería al despliegue. En particular, tal como se menciona en los protocolos internos facilitados por el encargado del tratamiento, se contempla la verificación del entorno del servidor dentro del marco de operativas de trabajo de su departamento de desarrollo. Sobre ese punto se indica lo siguiente en dicha documentación: “(...).
(...).”

No se ha encontrado mención a la revisión de la micro-caché ni verificación de parámetros similares.

Por último, el encargado del tratamiento ha facilitado información relativa a las medidas de seguridad del entorno tecnológico. (...).

4.2. Motivo por el cual las medidas de seguridad implantadas no han impedido el incidente.

Como se ha señalado, las medidas de seguridad se encontraban enfocadas a la prevención de ataques por parte de terceros maliciosos, así como posibles intrusiones en el sistema. No se han acreditado mecanismos específicos focalizados a la revisión de los parámetros del servidor ni, en particular, verificación de la micro-caché.

4.3. Medidas técnicas y organizativas adoptadas para evitar, en lo posible, incidentes como el sucedido.

MAD COOL manifiesta la adopción de las siguiente medidas y propuestas enfocadas en esta línea:

- Revisión del sistema de protección de datos: se aporta documento de seguridad de los datos, realizado por la entidad *****CONSULTORA.2.**, cuyo ámbito se encuentra enfocado a la responsabilidad proactiva del responsable del tratamiento (“*presente documento se elabora con el propósito de dar cumplimiento a lo establecido en el artículo 32 del precitado Reglamento (UE) 2016/679*”, “*MAD COOL FESTIVAL SL, que, como responsable del tratamiento, se compromete a adoptar las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo*”).
- Contratación de proveedores de confianza: MAD COOL manifiesta que recurre a “*proveedores o encargados de tratamiento fiables y que nos ofrezcan suficientes garantías de cumplimiento de las medidas técnicas y organizativas necesarias a la hora de prestar su servicio*”.

Tal como indican, consideran que su actual proveedor ofrece dichas garantías. Como muestra de ello, aportan acreditación de la comunicación que les fue realizada por el encargado alertando de los hechos, sobre la que previamente se ha tratado en el punto 2.5.

Por otra parte, el encargado del tratamiento indica que se ha implementado un software de aviso que, mediante una consulta a una marca de tiempo, se analiza si el servidor tiene micro-caché activo, enviando una alerta al equipo técnico y bloqueando la ejecución del programa.

Respecto al entorno de desarrollo, el encargado del tratamiento manifiesta que se han adoptado medidas adicionales como (...) y acciones de refuerzo en la puesta en producción de nuevas versiones, como metodologías ágiles y revisión del código.

5. Cumplimiento normativo.

5.1. Respecto del contrato de encargado del tratamiento

MAD COOL ha aportado sendas copias de los contratos de encargo de tratamiento, tanto a fecha del incidente (suscrito el 23 de enero de 2023) y como el vigente en la actualidad (suscrito el 17 de abril de 2023). El motivo de la firma de un nuevo contrato, según manifiesta MAD COOL sería: *“dicho contrato fue revisado y, tras ello, modificado en lo referente a las operaciones a realizar sobre los datos personales y que se recoge en el anexo del contrato. Este tipo de revisiones se realizarán periódicamente o cuando tenga lugar un incidente de este tipo a los fines de que el contrato se encuentre siempre perfectamente actualizado”*.

En ambos contratos consta la entidad *****CONSULTORA.1** actuando en calidad de encargada y MAD COOL FESTIVAL S.L. como responsable del tratamiento. En ambos contratos se comprueba que constan, entre otros aspectos:

- El objeto del contrato: prestación de servicios informáticos para eventos, siendo la actividad del responsable la de “organizador eventos” y la del encargado “servicios informáticos eventos”.

- Obligaciones del encargado: *“Tratar los datos de acuerdo con las instrucciones del responsable del tratamiento.*

Si el encargado del tratamiento considera que alguna de las instrucciones infringe el Reglamento (UE) 2016/679 o cualquier otra disposición en materia de protección de datos de la Unión o de los Estados miembros, el encargado informará inmediatamente al responsable”.

- “Llevar, por escrito, un registro que contenga (...) medidas técnicas y organizativas de seguridad”.

“Implantar las medidas de seguridad recogidas en el ANEXO del presente contrato.

En todo caso, el ENCARGADO DEL TRATAMIENTO deberá implantar mecanismos para:

a) Garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento.”

- Ante una violación de seguridad: *“El ENCARGADO DEL TRATAMIENTO notificará al RESPONSABLE DEL TRATAMIENTO, sin dilación indebida, y en cualquier caso antes del plazo máximo de 24 horas (...) las violaciones de la seguridad de los datos*

personales a su cargo de las que tenga conocimiento, juntamente con toda la información relevante para la documentación y comunicación de la incidencia.”

- Relativo a la subcontratación: *“EL ENCARGADO DEL TRATAMIENTO no podrá subcontratar ninguna de las prestaciones que formen parte del objeto de este contrato que comporten el tratamiento de datos personales, salvo los servicios auxiliares necesarios para el normal funcionamiento de los servicios del encargado.”*

Como diferencias, se aprecia tal como se manifiesta MAD COOL que en el contrato suscrito con posterioridad incluye más operaciones a realizar con los datos personales: *“organización, estructuración, adaptación o modificación, extracción, comparación o cotejo, combinación o interconexión y destrucción”*, además de las ya reflejadas en el contrato inicial.

Adicionalmente, el nuevo contrato también señala la necesidad de destrucción de los datos una vez finalice la prestación.

En relación con el subencargo de tratamiento con el proveedor *****COMPAÑIA.1**, MAD COOL ha manifestado lo siguiente: *“Al tratarse de un proveedor de (...), este nos informa que el servicio de *****COMPAÑIA.1** se contrata directamente online, aceptando en el momento de la contratación los términos legales de *****COMPAÑIA.1**”*. Adicionalmente, señalan que no existen comunicaciones mantenidas con *****CONSULTORA.1** relativas a la subcontratación de servicios informáticos.

Se aporta copia del clausulado, disponible en la página web de este proveedor (...). Entre los diferentes puntos, consta uno dedicado al encargo de tratamiento, para el que se señala lo siguiente: *“El cliente es en todo caso el Responsable del Tratamiento de los datos alojados en sus servicios de alojamiento. Por defecto, los servicios de hosting de *****COMPAÑIA.1** incorporan un sistema de microcaché. Si el cliente necesita que esta microcaché sea desactivada de su servicio para cumplir con algún aspecto de la normativa de protección de datos, deberá solicitar esta desactivación de forma explícita a nuestro equipo técnico a través de nuestro sistema de tickets.”*

Acorde a esa cláusula, el origen que la micro-caché se encontrara habilitada estaría ahí recogido, debiendo ser el responsable o el encargado del tratamiento las entidades que debieran haber solicitado su desactivación previa a la puesta en producción del formulario.

5.2. Normativa relativa al tratamiento afectado.

MAD COOL ha aportado la siguiente documentación:

- Registro de Actividades de Tratamiento, con fecha del 5 de mayo de 2023. Según manifiesta MAD COOL, el tratamiento afectado se incluiría bajo la denominación “clientes”, en la Actividad de Tratamiento número 2 del documento aportado. Se considera un tratamiento con un riesgo estándar, sin riesgos específicos.

En dicho tratamiento consta la entidad *****CONSULTORA.1** como encargado de tratamiento, en calidad de prestación de servicios informáticos de eventos. No se ha localizado referencia a la entidad *****COMPAÑIA.1**.

- Análisis de Riesgos: se ha aportado documentación acreditativa del análisis de riesgo realizado el 1 de febrero de 2023. Dicho análisis ha sido elaborado por *****CONSULTORA.2**. Entre las amenazas analizadas no se ha observado ninguna similar al suceso acontecido, sí contemplándose *“Contratar con un encargado del tratamiento que no ofrezca las garantías suficientes para aplicar las medidas técnicas y organizativas apropiadas”* y *“Errores humanos”*.

La valoración del análisis ofrece como resultado un riesgo residual aceptable, señalando entre otros aspectos *“este análisis de riesgos en el tratamiento de datos personales no es sino un ejercicio teórico que requiere su puesta en práctica de forma íntegra para garantizar los derechos y las libertades de los interesados. Es fundamental que se realice una adecuada supervisión y una posterior revisión de la implantación de las medidas de control propuestas en el análisis de riesgos para reducir el riesgo inherente hasta un riesgo residual que permita llevar a cabo el tratamiento garantizando los derechos y libertades de las personas físicas”*.

6.- Otros aspectos.

6.1. Valoración de la brecha mediante la herramienta Comunica-Brecha de la Agencia Española de Protección de Datos.

Se ha realizado una simulación, a partir de los datos recopilados sobre esta brecha, de la necesidad de realizar comunicación de la brecha. La valoración obtenida ha sido:

“NO SERÍA NECESARIO COMUNICAR LA BRECHA DE SEGURIDAD A LOS AFECTADOS conforme al art. 34 del RGPD al no apreciarse que pueda existir un riesgo alto o muy alto para los derechos y libertades de los sujetos afectados. No obstante, podría valorar hacerlo de forma voluntaria, como ejercicio de transparencia y responsabilidad proactiva.”

En cualquier caso, tal como se señala sobre esta herramienta, es una ayuda a la toma de decisiones, pero esta última corresponde ineludiblemente a la persona responsable de tratamiento y en ningún caso su utilización representa el pronunciamiento de esta Agencia sobre la aplicación del art. 34 del RGPD para una brecha de datos personales concreta.

6.2. Respecto de la formación de los empleados del encargado del tratamiento.

El encargado del tratamiento ha manifestado en el contrato del encargo de tratamiento de fecha (...) de 2023 que se siguen una serie de buenas prácticas y protocolos internos para garantizar la seguridad de la información y protección de datos personales. Entre ellas se encontraría (...).

De manera complementaria, manifiesta que durante el proceso de incorporación se importen procedimientos específicos relacionados con la seguridad de la información y la ciberseguridad. Se aporta copia de los códigos internos del departamento de desarrollo.

QUINTO: Con fecha 7 de enero de 2025, la Presidencia de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la parte reclamada, por la presunta infracción del artículo 5.1.f) del RGPD y del artículo 32 del RGPD, tipificadas en el artículo 83.5.a) y 83.4 a), respectivamente, del RGPD.

SEXTO: Notificado el citado acuerdo de inicio conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP) y transcurrido el plazo otorgado para la formulación de alegaciones, se ha constatado que no se ha recibido alegación alguna por la parte reclamada.

El artículo 64.2.f) de la LPACAP -disposición de la que se informó a la parte reclamada en el acuerdo de apertura del procedimiento- establece que si no se efectúan alegaciones en el plazo previsto sobre el contenido del acuerdo de iniciación, cuando éste contenga un pronunciamiento preciso acerca de la responsabilidad imputada, podrá ser considerado propuesta de resolución. En el presente caso, el acuerdo de inicio del expediente sancionador determinaba los hechos en los que se concretaba la imputación, la infracción del RGPD atribuida a la reclamada y la sanción que podría imponerse. Por ello, tomando en consideración que la parte reclamada no ha formulado alegaciones al acuerdo de inicio del expediente y en atención a lo establecido en el artículo 64.2.f) de la LPACAP, el citado acuerdo de inicio es considerado en el presente caso propuesta de resolución.

SÉPTIMO: Notificado el acuerdo de inicio y antes de que esta Autoridad dictase resolución, con fecha 20 de enero 2025 tuvo entrada escrito de MAD COOL por el que aportaba justificante de pago con reducción por pronto pago (20%). Con fecha 17 de febrero de 2025 tiene entrada nuevo escrito de MAD COOL por el que confirma la renuncia a cualquier acción o recurso en vía administrativa, de acuerdo con lo dispuesto en el artículo 85.3 de la LPACAP.

OCTAVO: De acuerdo con el informe recogido de la herramienta AXESOR, la entidad MAD COOL es una empresa constituida en el año 2015, y con un volumen de negocios de (...) euros en el año 2021.

A la vista de todo lo actuado, por parte de la Agencia Española de Protección de Datos en el presente procedimiento se consideran hechos probados los siguientes,

HECHOS PROBADOS

PRIMERO: Con fecha 11 de abril de 2023, MAD COOL realizó el lanzamiento de un formulario de confirmación de los datos personales de los usuarios que habían adquirido entradas para el festival que se celebraba en el mes de julio de ese año.

SEGUNDO: Durante la mañana del lanzamiento del formulario web, se realizó una migración de la plataforma a un servidor nuevo y, en el transcurso de dicha migración, no fue desactivada una micro-caché existente en ese servidor. Esta micro-caché de dos segundos ocasionaba que desde que un usuario accedía al formulario, durante un

máximo de 2 segundos, los siguientes usuarios que accedían vieran sus datos. Una vez transcurrían esos 2 segundos, los datos del usuario dejaban de mostrarse.

TERCERO: El incidente se mantuvo entre las 14:45 y las 15:15 y afectó a (...) usuarios.

De entre ellos, se habría producido con seguridad la pérdida de confidencialidad de datos personales de 406. Los datos afectados por la brecha fueron: nombre y apellidos; dirección postal, número de teléfono y correo electrónico. La brecha de datos personales fue comunicada por MAD COOL a través de un comunicado publicado en su página web con fecha 13 de abril de 2023.

CUARTO: La migración fue realizada por el encargado de tratamiento de MAD COOL-*****CONSULTORIA.1-**, quien gestionó a nivel técnico el incidente. No obstante, el entorno tecnológico se encontraba desplegado en la infraestructura de un tercero en calidad de subencargado del tratamiento, la entidad *****COMPAÑIA.1**. Dicha empresa ofrece por defecto un servicio de micro-caché para acelerar la carga de páginas webs. En los protocolos internos del encargado del tratamiento, relativos a la verificación del entorno del servidor no se menciona la revisión de la micro-caché ni la verificación de parámetro similares.

QUINTO: El servicio de *****COMPAÑIA.1** se contrata directamente online, aceptando en el momento de la contratación los términos legales de la web. Entre dichos términos, el dedicado al encargo de tratamiento señala lo siguiente:

*El cliente es en todo caso el Responsable del Tratamiento de los datos alojados en sus servicios de alojamiento. Por defecto, los servicios de hosting de *****COMPAÑIA.1** incorporan un sistema de microcaché. Si el cliente necesita que esta microcaché sea desactivada de su servicio para cumplir con algún aspecto de la normativa de protección de datos, deberá solicitar esta desactivación de forma explícita a nuestro equipo técnico a través de nuestro sistema de tickets."*

Acorde con esa cláusula, la micro-caché se encuentra habilitada por defecto, salvo que el responsable o el encargado del tratamiento hubieran solicitado su desactivación previa a la puesta en producción del formulario.

SEXTO: Las medidas de seguridad que se encontraban disponibles en el momento de la brecha (...) estaban enfocadas a ataques maliciosos por parte de terceros. Medidas como la implantación de una VPN fueron adoptadas con posterioridad a la brecha de datos personales.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la

Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II

Cuestiones previas

En el presente caso, de acuerdo con lo establecido en el artículo 4.1 y 4.2 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que MAD COOL realiza, entre otros tratamientos: la recogida y conservación de datos personales de personas físicas: nombre, apellidos, correo electrónico, teléfono, dirección postal, código postal, población y país.

MAD COOL realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD.

III

Obligación incumplida. Integridad y confidencialidad

La letra f) del artículo 5.1 del RGPD propugna:

"1. Los datos personales serán:

(...)

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»)."

El citado principio de confidencialidad obliga a los responsables del tratamiento a garantizar que los datos personales sean tratados de manera segura, evitando accesos no autorizados, usos indebidos o divulgación a terceros no autorizados. Esto incluye implementar medidas técnicas y organizativas adecuadas para proteger los datos frente a posibles brechas de datos personales, tanto externas como internas. Estas medidas deben ser apropiadas a los riesgos que puedan derivarse del tratamiento, y deben ser revisadas y actualizadas periódicamente para garantizar su eficacia.

En este caso, el principio de confidencialidad habría sido vulnerado debido a un fallo técnico en la configuración del servidor que alojaba el formulario de confirmación de datos personales. Durante la migración a un nuevo servidor, la micro-caché activa en el sistema habría permitido que los datos personales de un usuario que accedía al formulario fueran visibles durante unos segundos por otros usuarios que ingresaban en ese intervalo. Este fallo técnico habría expuesto datos personales de forma no autorizada, comprometiendo su confidencialidad. Con independencia de la duración de la brecha de datos personales la exposición constituiría un tratamiento no autorizado, dado que los datos personales de los usuarios fueron accesibles para terceros sin su consentimiento.

La parte reclamada, como responsable del tratamiento, tiene la obligación de garantizar la seguridad de los datos personales durante todo el proceso de tratamiento. En el presente caso, de las actuaciones de investigación se desprende que no se habrían implementaron controles suficientes para garantizar que el servidor estuviera configurado correctamente antes del lanzamiento del formulario. La decisión de realizar una migración en un momento crítico, el mismo día del lanzamiento, sin realizar las pruebas adecuadas para identificar posibles fallos técnicos, pone de manifiesto una grave negligencia del responsable del tratamiento que posibilitó directamente la brecha de datos personales.

El mencionado incidente evidencia una presunta vulneración del principio de confidencialidad previsto en el artículo 5.1 f) del RGPD. Aunque la parte reclamada tomó medidas para cerrar el formulario y minimizar el impacto, a los efectos de contener los daños, el error en la configuración del servidor y la falta de medidas preventivas adecuadas permitieron la exposición no autorizada de datos personales, lo cual manifiesta una deficiencia en las medidas técnicas y organizativas implementadas.

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de resolución de procedimiento sancionador, se considera que los hechos conocidos son constitutivos de una infracción, imputable a MAD COOL, por vulneración del artículo transcrito anteriormente.

IV

Tipificación de la infracción del artículo 5.1.f) del RGPD y calificación a efectos de prescripción

El artículo 83.5 del RGPD tipifica como infracción administrativa la vulneración del artículo siguiente, que se sancionará, de acuerdo con el apartado 2, con multas administrativas de 20.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

"a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9;"

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

“Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”.

A los solos efectos del plazo de prescripción, el artículo 72.1 de la LOPDGDD establece lo siguiente:

“En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679.”

V

Propuesta de sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.

2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;

b) la intencionalidad o negligencia en la infracción;

c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;

d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;

e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;

f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;

g) las categorías de los datos de carácter personal afectados por la infracción;

h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;

- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y*
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”.*

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado”.*

En el presente caso, considerando la gravedad de la posible infracción, atendiendo especialmente a las consecuencias que su comisión provoca en los afectados, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, el volumen de negocio de MAD COOL **357.000** euros en el año 2021.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 5.1.f) del RGPD, permite fijar una sanción de multa administrativa de 2.000,00 euros.

VI

Obligación incumplida. Seguridad del tratamiento

El artículo 32 del RGPD estipula lo siguiente:

"1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;*
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros."

El citado artículo 32 del RGPD tiene como objetivo garantizar un nivel de seguridad adecuado al riesgo, en relación con un tratamiento de datos personales, teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas. Así, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas de seguridad para garantizar dicho nivel de seguridad adecuado al riesgo. Conviene señalar que para considerar incumplido dicho artículo no resulta necesario que se haya producido un tratamiento indebido o una brecha de datos personales, sino que el simple hecho de no haber adoptado o implementado medidas técnicas y organizativas adecuadas constituye una infracción del mencionado artículo.

En el presente caso, a pesar de las medidas de seguridad existentes antes de la brecha de datos personales, como la implementación de HTTPS y la protección CSRF, destaca la ausencia de una medida de seguridad que fue adoptada posteriormente de forma reactiva tras el acaecimiento de la brecha de datos personales, medida de

seguridad independiente de la brecha de datos personales: la implementación de VPN para asegurar las comunicaciones entre los usuarios autorizados y los servidores. Así, durante el transcurso de las actuaciones de investigación la parte reclamada afirmó lo siguiente:

“Respecto al entorno de desarrollo, el encargado del tratamiento manifiesta que se han adoptado medidas adicionales como (...) y acciones de refuerzo en la puesta en producción de nuevas versiones, como metodologías ágiles y revisión del código.”

De dicha afirmación, se desprende que la entidad adoptó la implementación de una VPN de forma reactiva, tras la brecha de datos personales, lo que evidencia que esta medida no estaba implantada con anterioridad. La naturaleza de la actividad desarrollada, que incluye el acceso remoto y la gestión de datos personales sensibles en un entorno de servidores, hace que la adopción de una VPN sea una medida esencial para garantizar la seguridad de las comunicaciones y prevenir accesos no autorizados.

La implementación de una VPN en este contexto permite establecer una capa adicional de protección, asegurando que las conexiones entre los usuarios y los servidores se realicen de forma cifrada y segura. Ello es particularmente relevante en actividades donde los accesos al entorno tecnológico suponen un riesgo inherente de exposición o intrusión si no se adoptan medidas como esta. Al no contar con una VPN previa al incidente, no se habría garantizado un nivel de seguridad proporcional al riesgo, lo que supondría un incumplimiento del artículo 32 del RGPD.

Como se indicó anteriormente, el artículo 32 exige la adopción de medidas técnicas y organizativas apropiadas de seguridad para garantizar un nivel de seguridad adecuado al riesgo en los derechos y libertades de las personas físicas derivados del tratamiento de datos personales. La ausencia de esta medida de seguridad, que es básica, ya que la VPN es ampliamente reconocida como una práctica estándar para proteger datos en entornos tecnológicos similares, pondría de manifiesto un defecto en la identificación, evaluación y gestión de riesgos por parte de la entidad. La falta de esta medida de seguridad es independiente de la brecha de datos personales, pues su ausencia ni ha posibilitado ni ha tenido incidencia directa en la brecha de datos personales.

En consecuencia, la omisión de su implementación constituiría una infracción del citado artículo 32 RGPD, independientemente de que la brecha de datos personales haya ocurrido o no, al no haber adoptado medidas de seguridad apropiadas para garantizar un nivel de seguridad adecuado al riesgo; en el presente caso, la no implementación de una VPN.

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de resolución de procedimiento sancionador, se considera que los hechos conocidos son constitutivos de una infracción, imputable a MAD COOL, por vulneración del artículo transcrito anteriormente.

VII

Tipificación de la infracción del artículo 32 del RGPD y calificación a efectos de prescripción

El artículo 83.5 del RGPD tipifica como infracción administrativa la vulneración del artículo siguiente, que se sancionará, de acuerdo con el apartado 2, con multas administrativas de 20.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

"a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9;"

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

"Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica".

A los solos efectos del plazo de prescripción, el artículo 72.1 de la LOPDGDD establece lo siguiente:

"En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679."

VIII

Propuesta de sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

"1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.

2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;

b) la intencionalidad o negligencia en la infracción;

c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;

d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;

- e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;
- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;
- g) las categorías de los datos de carácter personal afectados por la infracción;
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”.

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado”.*

En el presente caso, considerando la gravedad de la posible infracción, atendiendo especialmente a las consecuencias que su comisión provoca en los afectados, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, el volumen de negocio de MAD COOL de (...) euros en el año 2021.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 32 del RGPD, permite fijar una sanción de multa administrativa de 1.500,00 euros.

IX

Teniendo en cuenta lo anterior, ha de señalarse que, de acuerdo con los preceptos de la LPACAP y la jurisprudencia del tribunal Supremo en esta materia, el pago voluntario por el presunto responsable no exime a la Administración de la obligación de resolver y notificar todos los procedimientos, cualquiera que sea su forma de iniciación.

De igual forma, el artículo 88 de la citada norma, establece que la resolución que ponga fin al procedimiento decidirá sobre todas las cuestiones planteadas por los interesados y aquellas otras derivadas del mismo.

Por lo tanto, la Presidencia de la Agencia Española de Protección de Datos

RESUELVE:

PRIMERO: DECLARAR la comisión de las siguientes infracciones y CONFIRMAR a los efectos previstos en el artículo 64.2 b) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, las sanciones indicadas en el acuerdo de inicio del presente procedimiento sancionador por la comisión de las citadas infracciones:

- Por la infracción del artículo 5.1 f) del RGPD: 2.000, 00 euros
- Por la infracción del artículo 32 del RGPD: 1.500, 00 euros

La suma de las citadas cuantías es de un total de 3.500, 00 euros

Tras haber procedido la parte reclamada al pronto pago, aunque sin reconocimiento de responsabilidad, se procede, en virtud del artículo 85 de la LPACAP, a la reducción de un 20 % del total mencionado, lo cual supone la cantidad definitiva de **2.800,00 euros**.

SEGUNDO: DECLARAR la terminación del procedimiento por el pronto pago realizado por MAD COOL, con NIF B87381042, en virtud de lo dispuesto en el artículo 85 de la LPACAP.

TERCERO: De acuerdo con lo previsto en el artículo 85 de la LPACAP que condiciona la reducción por pago voluntario al desistimiento o renuncia de cualquier acción o recurso en vía administrativa, por parte de la presente autoridad se acepta la renuncia expresamente manifestada por la parte reclamada, no cabiendo en consecuencia la interposición de recurso potestativo de reposición frente a la presente resolución, todo ello sin perjuicio de la posibilidad de acudir a la vía jurisdiccional contencioso-administrativa

En consecuencia, teniendo en cuenta lo dispuesto en el artículo 90 de la LPACAP, dado que no cabe ningún recurso en vía administrativa al haber renunciado

expresamente, la presente resolución será plenamente ejecutiva a partir de la notificación de la misma.

No obstante, conforme a lo previsto en el artículo 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-100325

Lorenzo Cotino Hueso
Presidente de la Agencia Española de Protección de Datos